

KYRO — FERPA Compliance Overview

Knowledge Yielding Resource Optimizer · How KYRO safeguards student education records *Version 1.0 — July 2026*

1. Purpose

This document describes the technical and organizational safeguards KYRO implements to help schools meet their obligations under the **Family Educational Rights and Privacy Act (FERPA, 20 U.S.C. § 1232g; 34 CFR Part 99)**. It is intended for school administrators, business officers, boards, and IT/security reviewers evaluating KYRO.

FERPA is a shared responsibility. The **school** is the FERPA-covered entity and the owner of its education records; **KYRO** is a service provider that processes those records on the school's behalf and under its direction. This document explains what KYRO does to protect that data and where the school's own responsibilities begin (Section 8).

KYRO is **designed to support FERPA compliance** and implements safeguards consistent with FERPA's requirements. FERPA does not offer a government "certification"; no vendor can be "FERPA-certified." This document is a good-faith description of KYRO's controls, not a legal opinion.

2. KYRO's role under FERPA — the "school official" exception

FERPA permits a school to disclose education records, without prior parental consent, to a **school official with a legitimate educational interest** (34 CFR § 99.31(a)(1)). A third-party service provider qualifies as a "school official" when it:

1. Performs an institutional service or function for which the school would otherwise use employees;
2. Is under the **direct control** of the school with respect to the use and maintenance of education records;
3. Uses education records **only** for the authorized purpose; and
4. Does **not re-disclose** the information except as permitted.

KYRO operates on this basis. KYRO processes each school's data solely to provide the contracted financial and operational-intelligence services, uses it for no other purpose, does not sell it or use it to train third-party AI models, and does not re-disclose it. These

commitments are memorialized in the school's service agreement / data protection addendum (Section 8).

3. Data minimization — aggregate by design

KYRO's core product operates on **institution-level financial and operational data** — trial balances, statements, budgets, enrollment counts by grade, and aggregate demographics. It is **not** a student information system and does **not** require student-level records to function. Where enrollment or demographic data is ingested, KYRO stores **aggregate counts** (e.g., "24 students in grade 1," "113 female / 130 male"), not individual student rows.

This *data-minimization-by-design* posture materially reduces FERPA exposure: the platform holds little to no personally identifiable information (PII) about individual students. Documents that a school chooses to upload (e.g., board packets, correspondence) are handled with the encryption, access-control, and deletion safeguards described below.

4. Technical safeguards

4.1 Encryption in transit — end-to-end TLS

All data moving to, from, and within KYRO is encrypted with TLS:

Segment	Protection
User's browser → KYRO edge (CloudFront)	TLS 1.3 (minimum TLS 1.2 enforced), managed certificate
Edge → application load balancer	HTTPS-only
Load balancer → application container	HTTPS (encrypted inside the private network)
Application → database	TLS required (<code>sslmode=require</code> , server-enforced <code>force_ssl</code>)
Application → storage & AWS services	HTTPS

There is no plaintext hop anywhere in the request path — encryption is **end-to-end**.

4.2 Encryption at rest

All stored data is encrypted at rest with **AWS KMS customer-managed keys (CMKs)** with automatic key rotation:

- **Database** (financial and operational data) — KMS-encrypted; automated encrypted backups with point-in-time recovery; never publicly accessible.

- **Document storage** — server-side encryption with a KMS CMK; a bucket policy **denies any non-TLS request**; all public access is blocked.
- **Secrets** (application credentials) — stored in a managed secrets vault, KMS-encrypted, injected into the application at runtime (never written to disk or source control).

4.3 Access control & tenant isolation

- **Authentication**: password credentials are stored only as salted hashes; session tokens are short-lived; password-reset codes are cryptographically random and single-use.
- **Role-based access**: users see only the schools and modules they are entitled to; owner/accountant/viewer roles gate sensitive actions.
- **Tenant isolation**: every request is scoped to the caller's school/organization; a request for another tenant's data is **rejected (HTTP 403)**. This is enforced server-side and verified by automated tests.
- **Least privilege**: the application's cloud identity can access only its own resources; human administrative credentials are separated from application credentials.

4.4 Artificial-intelligence privacy

KYRO's AI assistant ("Penny") and insights run on **Amazon Bedrock within KYRO's own AWS account** — the model provider does not receive the data for training and **nothing leaves the account**. In addition: - A **PII-redaction layer** tokenizes party/family names and similar identifiers before they reach the model, and restores them only for the authenticated caller. - **No external LLM API keys** are configured in production, so there is no path for education data to be sent to a third-party AI service.

4.5 Network isolation & perimeter

- The application runs in **private subnets** with no public IP address; the database is unreachable from the internet.
- A **Web Application Firewall (WAF)** with managed rule sets and per-IP rate limiting protects the public edge.
- Inbound access to the application is restricted to the load balancer; outbound access is limited to the services the platform requires.

4.6 Audit logging & monitoring

- **Infrastructure audit**: AWS CloudTrail records control-plane activity across the account.
- **Application audit**: security-relevant events (logins, record changes, deletions, data-erasure actions) are recorded in an application audit log with actor, action, and timestamp.

5. Data retention & deletion

- **Retention:** a scheduled process purges audit and operational records past their retention window; retention periods are configurable.
- **Deletion / right to erasure:** KYRO provides account-, school-, and organization-level deletion. Deletion runs as an atomic transaction that removes the associated records **and** purges the related documents from storage, and is recorded in the audit log. This supports a school's obligation to remove records and honor data-subject requests.

6. Infrastructure & hosting

KYRO is hosted on **Amazon Web Services (AWS)** in the United States. AWS maintains SOC 1/2/3, ISO 27001, and other independent attestations, and publishes its FERPA alignment. KYRO's account is configured with the encryption, isolation, logging, and least-privilege controls described above, and its encryption keys are logically isolated from any other tenant in the account.

7. FERPA control mapping

FERPA expectation	KYRO control
Disclosure only to school officials with a legitimate interest (§ 99.31(a)(1))	School-official service model; per-tenant access scoping; role-based access
Reasonable methods to protect records (§ 99.31(a)(1)(ii); § 99.32)	End-to-end TLS; KMS encryption at rest; WAF; private network
Use only for authorized purpose; no re-disclosure	Contractual commitment; in-account AI (no third-party training/egress)
Direct control by the school over use/maintenance	Configurable retention; school-initiated deletion; data-processing addendum
Recordkeeping of access/disclosure (§ 99.32)	CloudTrail + application audit log
Ability to amend/remove records	Account/school/org deletion + document purge

8. Shared-responsibility model

Responsibility	KYRO	School
Encrypt data in transit & at rest	✓	
Isolate tenants; restrict access	✓	
Provide deletion & audit tooling	✓	
Keep AI/data in-account (no external egress)	✓	
Designate KYRO a "school official" in a written agreement		✓
Determine legitimate educational interest & who may access		✓
Provide the annual FERPA notification to parents/students		✓
Handle parent/eligible-student access & amendment requests	assists	✓
Follow the school's breach-notification obligations	assists	✓
Manage school-side user accounts & offboarding		✓

9. Contact

For a data-processing addendum, security questionnaire, or additional detail, contact **support@ourkyro.com**.

This overview reflects KYRO's production configuration as of July 2026 and is provided for informational purposes. It is not legal advice. Schools should consult their own counsel regarding FERPA obligations.